

VendorLens

Automated KYB & Vendor Due Diligence Platform

Product Requirements Document

For Procurement & Compliance Teams

Field	Value
Version	1.0
Last Updated	June 2025
Target Completion	Q3 2025
Classification	Internal Confidential
Document Owner	Product & Architecture Team
Review Cycle	Before each sprint planning

This document is for internal use only. Do not distribute outside of authorised teams.

1. What Problem Are We Solving?

Procurement and compliance teams today run vendor due diligence across disconnected tools — one for sanctions screening, another for company registry lookups, another for news searches — and then manually piece together a risk picture. The result is slow, inconsistent, and impossible to audit at scale.

1.1 Current Pain Points

Pain Point	Impact
Manual checks take 2–3 days per vendor	Delays commercial operations; creates bottlenecks
No unified risk view across tools	Analysts miss cross-source signals; incomplete picture
Inconsistent results between analysts	Same vendor may receive different risk assessments
No audit trail for adverse findings	Cannot defend decisions under regulatory scrutiny
Scrapers break with website changes	Requires constant engineering maintenance overhead

1.2 What Success Looks Like

- Any vendor screened in under 15 minutes, end to end
- Single risk report with source evidence for every finding
- Consistent, policy-aligned risk scores regardless of which analyst runs the check
- Full audit log with timestamps for every scan performed
- API-first architecture — no scrapers to break or maintain

2. What VendorLens Does

VendorLens is an automated due diligence platform built for procurement teams. Given a company name and website, it queries authoritative public data sources in parallel, then uses an AI analyst to synthesise raw data into a structured risk report. Only adverse findings are stored — clean signals are discarded immediately.

Core promise: For any company name and domain globally, produce an automated, evidence-backed adverse risk report in under 15 minutes — storing only confirmed negative findings, surfaced in a clear dashboard requiring zero manual data hunting.

2.1 Strategic Principles

Principle	What It Means in Practice
API-first, no scrapers	All data sourced from official APIs — zero maintenance overhead from website changes
Store only negatives	Minimal storage footprint; every database row is an actionable risk item
AI as analyst, not classifier	Large language model synthesises raw data flexibly without retraining
Multi-layer entity screening	Entity + directors + beneficial owners all screened in a single workflow
Jurisdiction-agnostic	Works for companies in any country using global public data sources

3. How a Vendor Check Works — Step by Step

Every scan follows a three-stage pipeline. All data collection runs in parallel across eight intelligence sources, then an AI layer synthesises and deduplicates the results, and the final report is stored and surfaced to the reviewer.

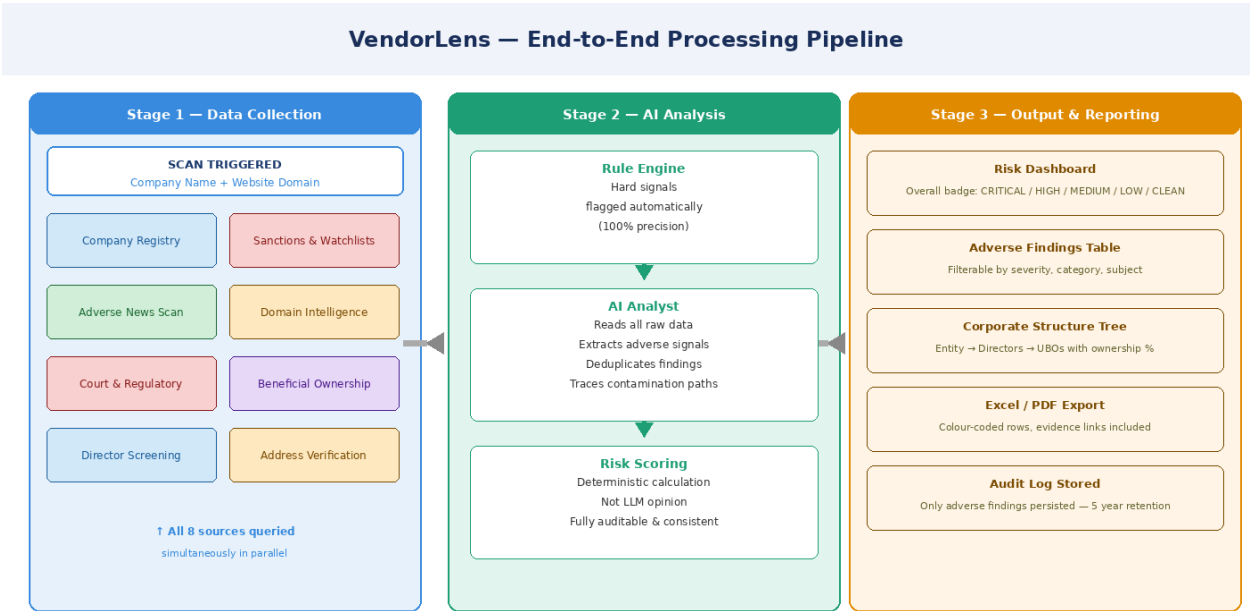


Figure 1: End-to-end VendorLens processing pipeline — Stage 1 queries run simultaneously before Stage 2 begins

3.1 Stage 1 — Data Collection (All Queries Run Simultaneously)

When a scan is triggered, eight groups of queries fire in parallel:

- Company registry lookup — verifies legal existence, status, and incorporation date

- Sanctions & watchlist screening — cross-checks against OFAC, UN, EU, and UK lists
- Domain intelligence — WHOIS registration date and SSL certificate validity
- Adverse news scan — searches global media indices for legal and crime keywords
- Court & regulatory records — checks court databases, SEC, and Justice.gov
- Beneficial ownership mapping — resolves UBOs and full ownership chains
- Director screening — individual sanctions, PEP, and adverse media checks per person
- Address verification — detects known shell company address clusters

All eight source groups are queried simultaneously. The system waits for all to complete before proceeding to AI analysis. This parallel architecture delivers the sub-15-minute turnaround.

3.2 Stage 2 — AI Analysis

Step	What Happens	Why It Matters
Rule engine	Hard signals (exact sanctions matches, domain age mismatch) flagged automatically with 100% precision	Ensures hard red flags are never missed regardless of AI output
AI analyst	LLM reads all raw data, extracts adverse signals, deduplicates across sources, and traces contamination paths	Handles nuanced multi-source interpretation that rule engines cannot
Risk scoring	Mathematical formula computes final score from finding severity and category weights — not LLM judgment	Keeps the score auditable, consistent, and defensible

3.3 Stage 3 — Output & Reporting

- Risk dashboard — overall risk badge (CRITICAL / HIGH / MEDIUM / LOW / CLEAN)
- Adverse findings table — filterable by severity, category, and subject name
- Corporate structure tree — entity with linked directors and UBOs and ownership percentages
- Excel and PDF export — colour-coded by severity with embedded evidence links
- Audit log — all adverse findings stored for 5 years for compliance evidence

4. Two Screening Tiers

The platform offers two levels of depth, allowing teams to run fast checks for low-risk vendors and forensic-grade diligence for high-risk or high-value engagements. Tier 1 can run independently; Tier 2 builds on Tier 1 results.

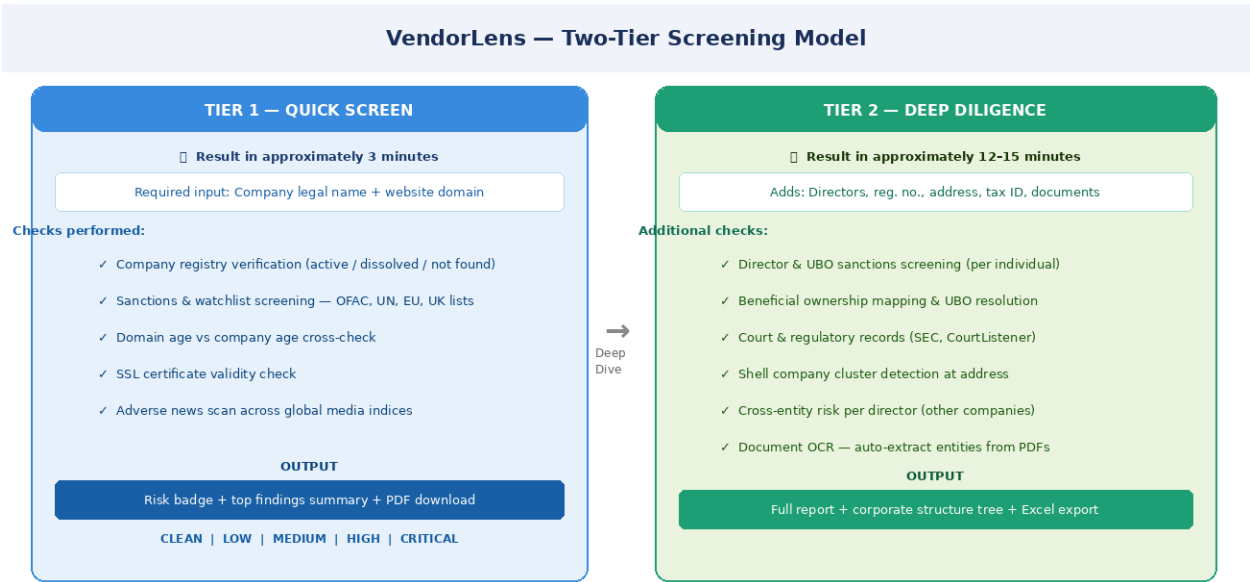


Figure 2: Side-by-side comparison of Tier 1 Quick Screen and Tier 2 Deep Diligence

4.1 Tier 1 — Quick Screen (~3 minutes)

Attribute	Detail
Inputs required	Company legal name + website domain only
Checks performed	Registry verification · Sanctions screening · Domain age & SSL · Adverse news scan
Output	Risk badge + top findings summary + PDF download option
Use case	Initial screening, existing vendor refresh, low-risk suppliers

4.2 Tier 2 — Deep Diligence (~12–15 minutes)

Attribute	Detail
Inputs required	Everything in Tier 1, plus: director names, registration number, address, tax ID, optional document uploads
Additional checks	Director/UBO sanctions · Ownership mapping · Court records · Shell address detection · Cross-entity director risk
Output	Full adverse findings report + corporate structure tree + Excel export (colour-coded by severity)

Attribute	Detail
Use case	New high-value supplier onboarding, escalated reviews, forensic diligence

4.3 Document Upload & OCR (Tier 2 Only)

Reviewers can upload vendor-provided documents — GST certificates, trade licences, invoices — directly into the platform. The system automatically extracts key fields including registration number, legal name, address, and signatory name.

- Supported formats: PDF, JPG, PNG
- Extracted fields auto-populate the form; reviewers can correct before submission
- All uploaded documents permanently deleted within 24 hours of extraction completing

Privacy note: Documents are processed locally and deleted automatically. They are never shared with third parties and are never stored beyond 24 hours.

5. What Data Is Collected

The platform accepts structured inputs across four categories. Tier 1 requires only two fields; Tier 2 unlocks the full input schema.

5.1 Category A — Primary Identifiers (Tier 1, Required)

Field	What It Is	Used For
Company legal name	The full registered legal name of the entity	Registry lookup, sanctions screening, news scan
Website domain	Official website domain only (e.g. acme.com)	Domain age check, SSL verification, WHOIS lookup

5.2 Category B — Regulatory & Corporate Identifiers (Tier 2)

Field	Examples	Purpose
Registration number	CIN (India), EIN (US), CRN (UK), HRB (Germany)	Confirm company status with the official registry
Country / jurisdiction	IN, US, GB, AE	Determines which registry API to query
Tax identifier	GSTIN, PAN, VAT, TIN	Verify tax registration is active and current
Registered address	Full address string	Shell company cluster detection

5.3 Category C — Key Personnel (Tier 2)

Field	Notes	Purpose
Director names	Up to 10 individuals	Sanctions screening, adverse media, PEP check per individual
Director ID numbers	DIN (India-specific)	Cross-entity risk — detect if director is on defaulted companies
Founder / CEO name	Primary individual for enhanced check	PEP check, Wikidata profile lookup

5.4 Category D — Digital Footprint (Tier 2)

Field	Notes	Risk Signal
Social handles	LinkedIn, Twitter/X, Facebook	Bot inflation patterns, complaint cluster analysis
Corporate email domain	e.g. @acme.com	Free email provider (Gmail, Outlook) = MEDIUM flag
Uploaded documents	GST cert, invoice, trade licence	OCR extracts entities for automated cross-verification

6. Where the Data Comes From

All intelligence is sourced from official, authoritative public APIs — no web scraping. Each source category targets a specific risk dimension.

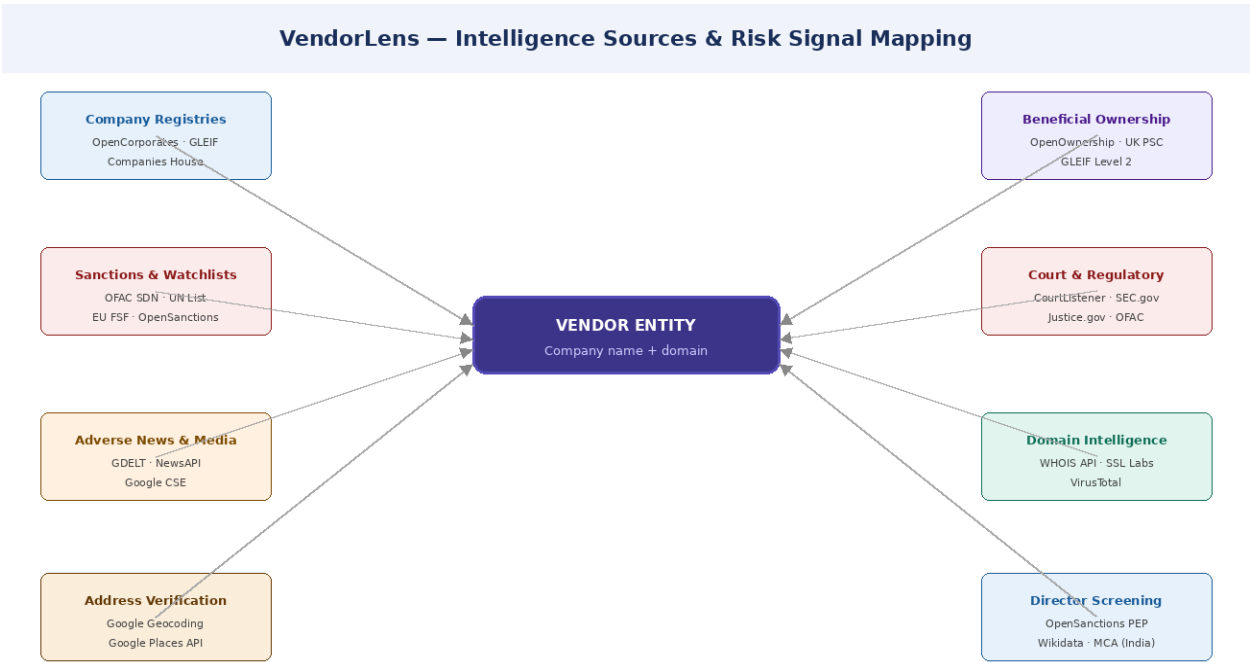


Figure 3: Intelligence sources mapped to the vendor entity — all seven categories queried simultaneously

6.1 Source-to-Risk Signal Mapping

Source	Category	Key Risk Signals
OpenCorporates	Entity integrity	Dissolved / struck off / new entity (< 12 months old)
GLEIF	Entity integrity	Lapsed LEI; branch entity flag; missing international records
OpenSanctions	Sanctions & watchlists	Score > 0.85 = CRITICAL; score 0.60–0.85 = HIGH (possible match)
OFAC XML	Sanctions & watchlists	Direct SDN list match = always CRITICAL; overrides all other scores

Source	Category	Key Risk Signals
WHOIS API	Domain anomaly	Domain registered years after claimed company founding date
SSL Labs	Domain anomaly	Expired, self-signed, or missing SSL certificate on commercial domain
GDELT	Adverse media	Negative-tone articles containing legal keywords (fraud, arrested, etc.)
NewsAPI	Adverse media	Fraud and corruption mentions in Tier-1 media outlets (Reuters, AP, BBC)
Google CSE	Court & regulatory	Results from CourtListener, SEC.gov, Justice.gov, OFAC.treas.gov
OpenOwnership	Director/UBO risk	Circular ownership chains; nominee director on 30+ companies
Google Geocoding	Entity integrity	Registered address matches known shell company address clusters

7. How Risk Is Assessed

Risk assessment happens in two layers: a deterministic rule engine flags hard signals with 100% precision, followed by the AI analyst that reads all raw data and extracts nuanced findings. The final risk score is computed mathematically — ensuring it is auditable and consistent.

VendorLens — Risk Assessment & Scoring Model		
Risk Level	What triggers this level	Recommended action
CRITICAL	Sanctions match · Director/UBO on OFAC or UN list	Block immediately — legal notification required
HIGH	Dissolved entity · Court records · 3+ adverse findings	Escalate to compliance officer — do not contract
MEDIUM	Domain mismatch · No SSL · Lapsed tax registration	Request documentation — proceed with caution
LOW	Single low-credibility mention · Minor anomaly only	Monitor — no immediate action required
CLEAN	No adverse findings detected across all sources	Approved for onboarding — schedule periodic re-screen
Finding Categories & Source Authority		
Sanctions & Watchlists	Entity Integrity	Adverse Media
Court & Regulatory	Domain Anomaly	Director/UBO Risk
Financial & Tax		

Figure 4: Risk level decision matrix — triggers and recommended actions per level

7.1 Risk Level Definitions

Level	What Triggers It	Recommended Action
CRITICAL	Sanctions match on any major list; director or UBO on OFAC or UN list	Block immediately — legal notification required
HIGH	Dissolved entity; court or regulatory record; 3+ adverse findings	Escalate to compliance officer; do not contract until resolved
MEDIUM	Domain age mismatch; missing SSL; lapsed tax registration	Request documentation from vendor; proceed with caution
LOW	Single low-credibility mention; minor anomaly only	Monitor; no immediate action required
CLEAN	No adverse findings detected across all sources	Approved for onboarding — schedule periodic re-screening

Important: Any single CRITICAL finding overrides the computed score. The overall risk level is always CRITICAL if any one finding is, regardless of other signals present in the scan.

7.2 Finding Categories

Category	What It Covers	Key Sources
Sanctions & watchlists	Matches on OFAC, UN, EU FSF, UK OFSI sanction programmes	OpenSanctions, OFAC XML, UN Consolidated List
Entity integrity	Dissolved status, new entity, shell address, circular ownership	OpenCorporates, GLEIF, OpenOwnership
Adverse media	Fraud, corruption, arrest, lawsuit mentions in news coverage	GDELT, NewsAPI, Google CSE
Court & regulatory	Litigation records, SEC filings, court judgements	CourtListener, SEC.gov, Justice.gov
Domain anomaly	Domain age vs company age; missing SSL; unregistered domain	WHOIS API, SSL Labs, VirusTotal
Director / UBO risk	Sanctioned individuals, PEP status, nominee director patterns	OpenSanctions, MCA (India), Wikidata
Financial & tax	Lapsed tax registration, missing financial filings	GST API, Companies House, GLEIF

7.3 How the Contamination Path Works

A key feature is tracing how a risk finding attaches to the vendor entity, even when the finding is about a connected individual or subsidiary. The system records this contamination path explicitly in every finding.

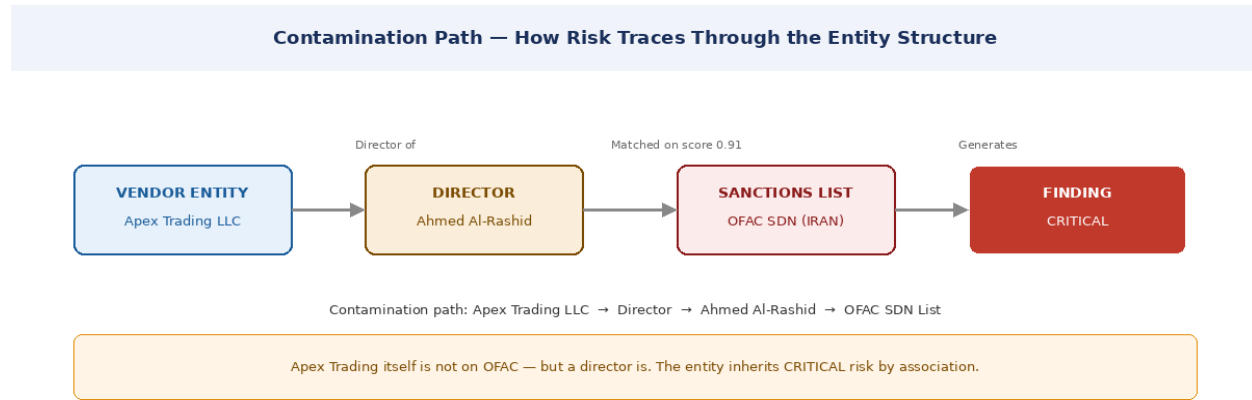


Figure 5: Contamination path example — risk traces from a director back to the vendor entity

7.4 Confidence Scoring

Score	Source Type
10	Official government source, verified court record, confirmed sanctions database
8–9	Tier-1 news outlet (Reuters, AP, BBC, Bloomberg), official company registry
6–7	Tier-2 news outlet, minor regulatory body, unverified breach database
4–5	Single-source finding, forum or social media, circumstantial signal
1–3	Weak signal, speculative, no corroboration from other sources

8. Sample Adverse Finding

Each finding stored in the system follows a consistent structure with full evidence tracing. Below is a representative example of what a CRITICAL sanctions finding looks like in the generated report.

CRITICAL Sanctions & Watchlist Confidence Score: 9 / 10
Finding ID: F001
Title: Director match on OFAC Specially Designated Nationals list
Subject: Ahmed Al-Rashid (Director, Apex Trading LLC)
Contamination path: Apex Trading LLC → Director → Ahmed Al-Rashid → OFAC SDN

Detail: Ahmed Al-Rashid, listed as a director since March 2021, appears on the OFAC Specially Designated Nationals list (programme: IRAN) with a match confidence score of 0.91. The match was corroborated by the OpenSanctions verified dataset. Engagement constitutes a compliance violation under OFAC regulations.

Evidence source: OFAC SDN List via OpenSanctions — finding date 2024-11-15

Recommended action: **BLOCK** — Immediately halt engagement; legal notification required.

9. Data Storage & Privacy

VendorLens uses a "store only negatives" data model. Clean signals are never written to the database. Only adverse findings are persisted, keeping every database row meaningful and the storage footprint minimal.

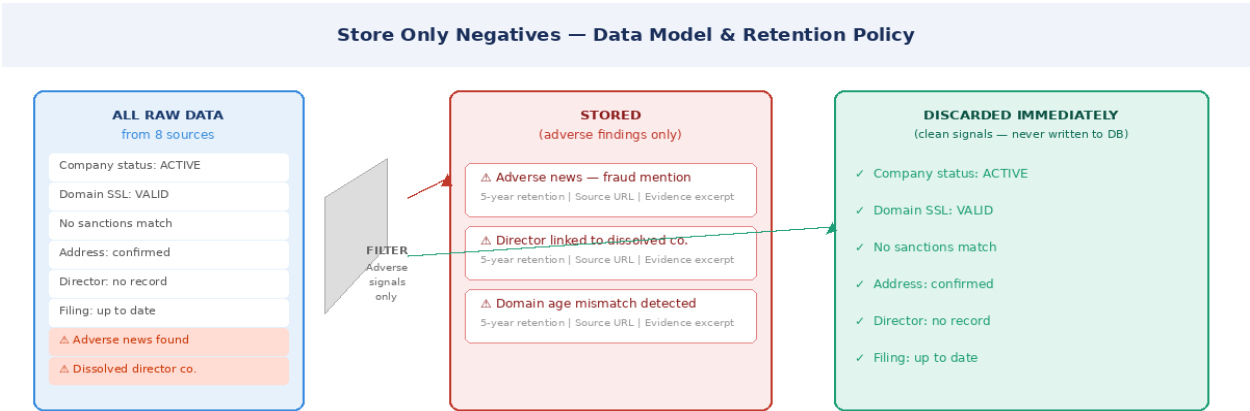


Figure 6: Store-only-negatives model — clean signals are discarded immediately after AI synthesis

9.1 Data Retention Policy

Data Type	What Is Stored	Retention	Rationale
Scan metadata	Company name, timestamp, risk level, score	5 years	Audit trail
Adverse findings	All negative findings with full evidence trails	5 years	Compliance evidence
Directors / UBOs	People discovered during the scan	5 years	Relationship mapping
Raw API responses	NOT stored — discarded after synthesis	Immediate	Privacy + storage minimisation
Clean signals	NOT stored anywhere	Immediate	Store-only-negatives principle
Uploaded documents	Deleted after OCR extraction	24 hours maximum	Privacy by design

9.2 Compliance Notes

- GDPR Article 22: System outputs are advisory only. Human review is required before any adverse action is taken against a vendor.
- Right to explanation: Every finding includes a source URL and verbatim excerpt from the original source data.
- Data minimisation: Raw API responses are never stored. Only synthesised adverse findings are persisted.
- Security: All API keys are stored in environment variables, never in code or the database. Database connections via SSL only.

10. Performance Targets

Operation	Target SLA
Tier 1 Quick Scan (end to end)	< 5 minutes
Tier 2 Deep Diligence (end to end)	< 15 minutes
API response to scan initiation	< 1000 milliseconds
Status polling endpoint	< 500 milliseconds
Excel report generation	< 10 seconds
Dashboard page load	< 5 seconds

Scalability: The system must handle 50 concurrent deep scans without performance degradation.
Task workers auto-scale from 4 to 20 under increased load.

11. Open Decisions Requiring Stakeholder Input

#	Question	Owner	Priority
1	Which AI provider — Anthropic Claude or OpenAI GPT-4o — at scale cost/latency tradeoff?	Architecture	HIGH
2	OpenCorporates free tier: 10 req/min limit. Do we need a paid plan at launch volume?	Product	HIGH
3	GDELT returns articles in 100+ languages — translation layer before AI synthesis?	Engineering	MEDIUM
4	India MCA DIN API has no official public endpoint — scraper needed or skip for v1?	Engineering	MEDIUM
5	Who owns and maintains the known shell address blocklist going forward?	Compliance	HIGH
6	Google Custom Search pricing at 10K+ queries/month — budget approval needed	Finance	MEDIUM
7	Re-screening cadence — how often should approved vendors be re-screened?	Compliance	LOW
8	Multi-tenant isolation model — one schema per org or row-level security?	Architecture	HIGH

11.1 Out of Scope for v1.0

Feature	Rationale for Deferral
Paid data vendors (Refinitiv World-Check, Dow Jones)	Public data first; deferred to v2
Real-time monitoring and re-screening alerts	Deferred to v2
Custom ML fraud classifier	LLM prompt covers this without model retraining
Mobile application	Web-only for v1
API access for external consumers	Internal tool only for v1
Dark web monitoring	Requires specialised vendor; outside public-data scope

Document Owner: Product & Architecture Team | Review Cycle: Before each sprint planning | Next Review: Prior to Engineering Kickoff